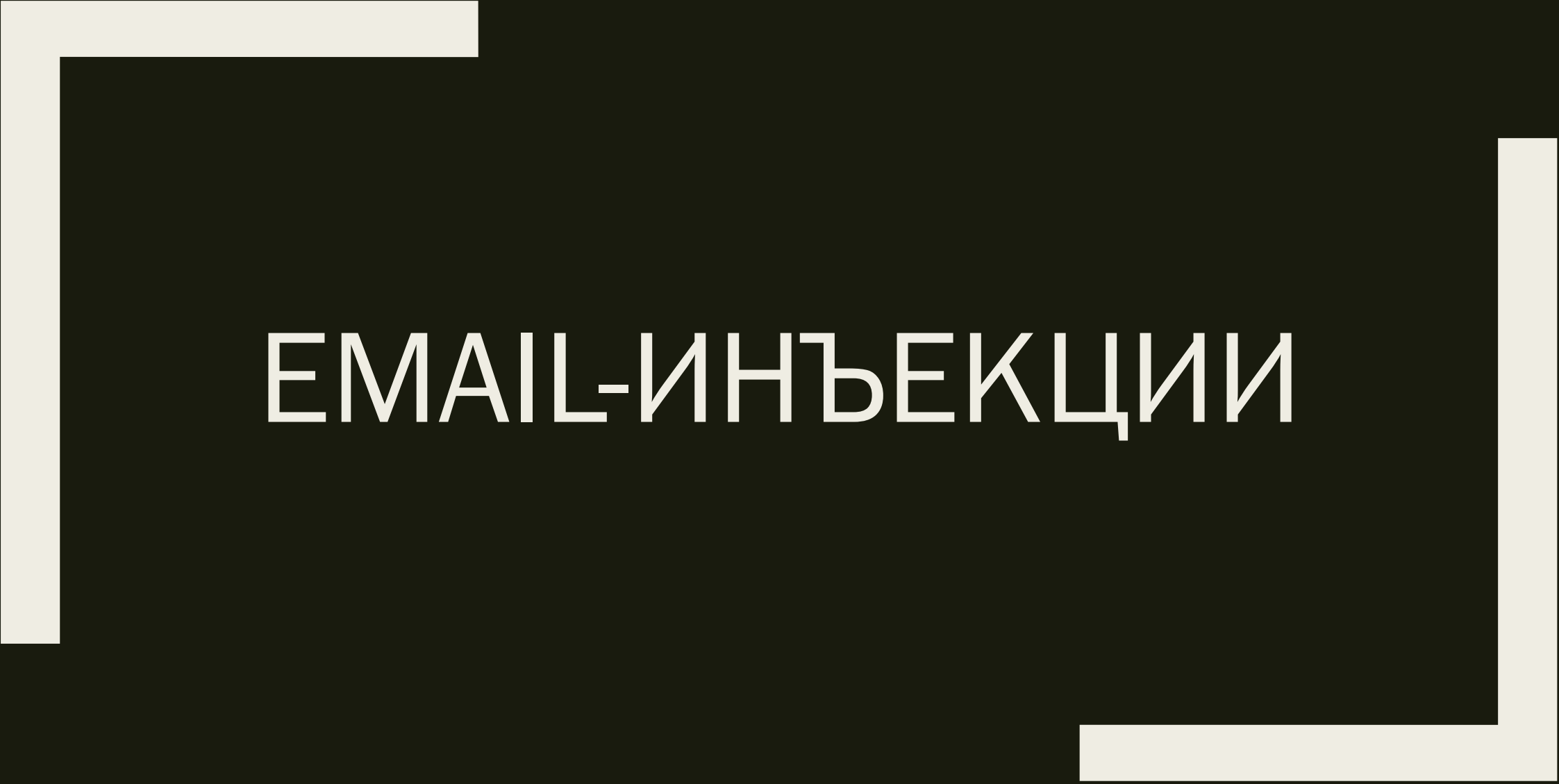


A large, stylized L-shaped frame made of thick white lines. The top-left corner is a horizontal line extending to the right, then a vertical line extending downwards. The bottom-right corner is a horizontal line extending to the left, then a vertical line extending upwards. The text is centered within the negative space of this frame.

EMAIL-ИНЪЕКЦИИ

e-mail инъекция — это техника атаки, используемая для эксплуатации почтовых серверов и почтовых приложений, конструирующих IMAP/SMTP выражения из выполняемого пользователем ввода, который не проверяется должным образом. В зависимости от типа операторов, используемых злоумышленником, выделяют два типа инъекций: IMAP инъекция и SMTP инъекция.

Введение

IMAP / SMTP инъекции позволяют получить доступ к почтовому серверу, к которому ранее доступа не было. В некоторых случаях эти внутренние системы не имеют того же уровня безопасности, что и остальная инфраструктура. Таким образом, злоумышленники могут обнаружить, что почтовый сервер, дает лучшие результаты с точки зрения эксплуатации. Этот метод позволяет избежать возможных ограничений, которые могут существовать на уровне приложений (CAPTCHA, максимальное количество обращений и т. д.).

Введение

Типичная структура IMAP / SMTP инъекции заключается в следующем:

Header: окончание ожидаемой команды

Body: инъекция новых команд

Footer: начало ожидаемой команды

Введение

Важно отметить, что для того, чтобы выполнились IMAP / SMTP команды, предыдущие команды должны были прекращены с CRLF (% 0d% 0a) последовательностью.

Введение

Некоторые примеры нападений с использованием IMAP / SMTP инъекции техники являются:

- ☐ Эксплуатация уязвимостей IMAP/SMTP протокола;
- ☐ Уклонение от ограничений приложений;
- ☐ Уклонение от антиробота;
- ☐ Утечка информации;
- ☐ Спам.

Примеры сценариев атак

IMAP инъекции поскольку инъекция проводится на сервере IMAP, формат и характеристики этого протокола должны соблюдаться. Почтовые приложения обычно взаимодействуют с сервером IMAP, чтобы выполнять свои функции в большинстве случаев и, следовательно, более уязвимы для атак такого типа.

Примеры сценариев атак

Давайте посмотрим на пример IMAP инъекции, использующей функциональные возможности чтения сообщений. Предположим, что приложение использует параметр веб-почты «message_id», чтобы сохранить идентификатор сообщений, которые пользователь желает прочитать. Когда запрос, содержащий идентификатор сообщения отправляется, это будет выглядеть следующим образом:

```
http:// <webmail> / read_email.php? message_id = <номер>
```


Примеры сценариев атак

Предположим, что php-скрипт «read_email.php», отвечающий за показ связанного с ним сообщения, передает запрос на сервер IMAP, не выполняя никаких проверок на значение <номер>, указанное пользователем. Команда, отправленная на почтовый сервер будет выглядеть следующим образом:

```
FETCH <number> BODY[HEADER]
```

Примеры сценариев атак

В связи с этим, злоумышленник может попытаться провести атаку IMAP инъекции через параметр «message_id», используемый приложением для связи с сервером. Например, команда IMAP «CAPABILITY» может быть введена, используя следующую последовательность:

```
http://<webmail>/read_email.php?message_id=1 BODY[HEADER]%0d%0aV001  
CAPABILITY%0d%0aV002 FETCH 1
```

Примеры сценариев атак

Это позволит произвести следующую последовательность команд IMAP на сервере:

```
???? FETCH 1 BODY[HEADER]
```

```
V001 CAPABILITY
```

```
V002 FETCH 1 BODY[HEADER]
```

Примеры сценариев атак

где:

Header = 1 BODY[HEADER]

Body = %0d%0aV100 CAPABILITY%0d%0a

Footer = V101 FETCH 1

SMTP инъекция

В этом случае внедрение команд производится в SMTP сервер, поэтому внедряемые команды должны следовать этому протоколу. Из-за того, что все проводимые операции разрешены приложением, используя SMTP протокол мы, проще говоря, имитируем отсылку письма. Использование SMTP инъекции предполагает, что пользователь предварительно аутентифицировался, т.е. необходимо чтобы имелся активный пользовательский аккаунт.

SMTP инъекция

Ниже приведён формат письма, посылаемого через SMTP:

- ☐ отправитель
- ☐ получатель
- ☐ тема
- ☐ тело письма
- ☐ присоединённые файлы

SMTP инъекция

При использовании данного метода необходимо, чтобы пользователь был аутентифицировал себя, тогда инъекция SMTP команды будет произведена в параметр, ассоциированный с темой отсылаемого письма. В общем случае, веб-приложение электронной почты предоставляет пользователю форму, где он должен ввести необходимую информацию, она затем будет передана процедуре, которая ответственна за создание SMTP команд, необходимых для отправки данного письма.

Сравнение IMAP и SMTP инъекций.

	IMAP инъекция	SMTP инъекция
требуется аутентифицированного пользователя	нет	да
Типы атак	Утечка информации, прямое использование IMAP протокола, обход технологии CAPTCHA	Утечка информации, прямое использование SMTP протокола, обход ограничений на релеинг/спам

Критерии защиты

Как и при других уязвимостях, приводящих к внедрению данных атакующим, защита веб-приложений электронной почты требует внедрения и применения необходимых мер, предлагаемых командой разработчиком. Однако, чтобы сузить возможность атакующего использующего данные уязвимости, необходимо применять более широкие меры по безопасности всего сервера.

Проверка вводимых данных

Все введённые данные, используемые приложением (не только введённые пользователем, но и используемые для внутренних нужд) должны быть нормализованы, должны быть удалены все символы, которые могут быть использоваться с умыслом. Проверки должны быть произведены до каких-либо манипуляций с данными.

Конфигурация IMAP/SMTP серверов

Если для доступа к почтовым серверам используется только веб-приложения, данные серверы не должны быть видны из Интернет. В дополнение к этому вы должны усилить ограничения для них, отключая все команды, за исключением действительно необходимых, для снижения угрозы атак инъекциями.

Файрволы уровня приложений

Если развертывается такой файрвол наряду с другими системами защиты - можно добавить соответствующие правила к фильтру.

инъекОно будет фильтровать внедрение последовательности ций.